

The Drift Layer: the clean, fast session that is not proof of authority

Matthew T. Kirby, Independent Researcher — matthew.kirby@driftlayer.org · driftlayer.org

The Drift Layer, paper no. 4 · Version 1 — 14 September 2026 · CC BY 4.0

Cite as: Kirby, M. T. (2026) *The Drift Layer: the clean, fast session that is not proof of authority*. Version 1, 14 September 2026. driftlayer.org

1. The clean, fast death

Merchant-side friction models lean on proxies for a human nervous system. Hesitation. Mouse movement. Repeated clicks. Typos. Abandonment. The signals are indirect, but the thing they are trying to detect is recognizably human: confusion, resistance, second thoughts, or a mismatch between what a person intended and what the checkout is asking them to do.

An autonomous agent can leave none of those traces.

It can execute a flawed purchase with absolute precision. A grocery substitution can change the thing being bought. An auction can clear above the limit the user had in mind. A quantity can be misread. The checkout can still look immaculate. No hesitation. No rage-click. No re-entry. No visible distress at all.

That is the clean, fast death.

The transaction can silently violate what the user meant to authorize while producing the behavioral signature of a perfect checkout. A system trained to read friction gets a reading with almost no information in it.

That matters because what gets measured and what needs to be known have come apart. What gets measured is whether the checkout proceeded cleanly. What needs to be known is whether the resulting purchase stayed inside the authority the user gave the agent.

Those are not the same thing.

Agentic commerce therefore creates a new kind of measurement problem before it creates a new liability problem. A clean completion is no longer evidence that the human would have accepted the completed transaction. It may mean only that the machine encountered no technical obstacle on the way to executing it.

The blind spot is not at the edge of the payment system. It begins before the payment is sent.

And once the transaction reaches the rails, the position gets worse.

2. The moment every protocol names and none defines

The major agentic-checkout protocols already recognize the moment when execution and authority come apart. They name it differently. They are not one specification.

OpenAI/Stripe's Agentic Commerce Protocol has a resolution value, `requires_buyer_review`. The protocol can therefore say that the buyer must come back into the loop. What it does not supply at that point is a signed object expressing the altered transaction the buyer actually approved.

The Universal Commerce Protocol names another version of the same boundary. It defines `mandate_scope_mismatch`: the proposed checkout no longer fits the mandate presented for it. The error identifies the mismatch. It does not itself define a remediation object that records a narrow amendment to the authority already given.

AP2 is a separate payments protocol. In its Human-Not-Present model, an agent can close within previously authorized bounds using its own key. That gives the system a way to distinguish the user's original authority from the agent's later act of execution. It does not, by itself, solve the next problem: what should happen when execution has moved outside those bounds but the user wants to approve only the delta rather than start again.

That is the missing moment.

The important distinction is between detecting divergence and resolving it. A system can know that a proposed transaction no longer fits its authority without possessing an artifact that records how the user changed that authority.

Without that artifact, the practical responses collapse toward coarse outcomes. Stop. Return to the buyer. Start a new approval journey. Reconstitute the authority around the changed transaction.

A small change is treated as a new transaction because the architecture has no small object for changing an existing mandate.

The failure is named. The cure is not.

The method of what follows depends on keeping those two problems on two planes.

The protocol gap is independent of the rail gap. A specification can name a mismatch and still lack an artifact that records how the user changed the authority. That gap does not wait on the rails. It would exist even if every subsequent payment message were perfectly transparent.

The rail gap is independent of the protocol gap. A rich mandate and a rich checkout can exist, and a successful payment can exist, without an observer possessing a durable key that joins them. The United Kingdom is used for that plane because it is an unusually inspectable public stack against which the join can be tested: dated consultation papers, versioned APIs, public mapping tables, public scheme documents. A private network that solved the join internally among its own participants would still leave the public measurement problem intact. The scoreboard cannot be scraped from settlement data. Visibility is part of the capability being tested.

The two planes meet only at the join. The rest of this paper treats them as two planes. On the protocol plane the failure is already named. On the rail plane, in the UK, the evidence generally does not survive.

3. The rails

Cards

The signed cart lives in HTTP, not on the card rail.

Agent-checkout protocols write it there directly. OpenAI/Stripe's Agentic Commerce Protocol defines a CheckoutSession object with a full line-item array — SKU, quantity, price — exchanged between agent, merchant and payment provider before any card message exists.

None of that establishes that the same object survives the handoff to the network.

What reaches the acquiring side of a conventional card transaction is the payment credential or network token and transaction data needed for authorization. Google's AP2 is explicit that its own payment mandate "may be shared with the network/issuer along with the standard transaction authorization messages." Alongside, not necessarily inside.

The authorization chain is private. Gateway to acquirer to scheme to issuer. Public Visa and Mastercard developer documentation opened on 28 August 2026 does not publish the UK-domestic VisaNet or Banknet ISO 8583 field dictionaries, so there is no public basis here for asserting how much additional mandate

material those messages could carry. The absence is an observability fact, not a measured capacity limit.

Settlement removes another layer of visibility.

Visa Europe, Mastercard Europe and LINK settle into the Bank of England's RTGS infrastructure on a net basis. What arrives there is a settlement obligation for the scheme, not the individual agent checkout with its cart and mandate attached.

Whatever semantic detail existed at checkout is already on another plane.

That distinction matters. A signed cart can be very rich while the observable payment movement is very poor. Improving the former does not automatically make the latter attributable.

Open Banking

Open Banking presents almost the reverse problem.

Evaluation is not missing on this plane. Projection is.

The current published Open Banking Standard is v4.0.1 (specification dated 18 March 2026; OBL announcement 1 April 2026). Under that Standard the ASPSP must evaluate a VRP payment against the consent's ControlParameters. If a control is breached, the ASPSP must fail the request and return error code U014, identifying the offending control in the error's Field member.

That is a real per-transaction evaluation against a named predicate.

It stays inside the API.

The error is returned to the initiating PISP over the channel on which the request arrived. The payment that breached the control is not released to Faster Payments or Bacs. It never becomes an interbank payment requiring a mark that says "failed mandate evaluation."

The failure case therefore leaves no failed payment on the rail.

The pass case is not better for an outside observer. A payment that satisfies the consent becomes an ordinary credit transfer. The public FPS and Bacs mappings contain no field saying that a VRP control evaluation occurred, what was evaluated, or that the payment passed it.

The identifier that survives is also not the identifier carrying the authority.

EndToEndIdentification is projected into Faster Payments. ConsentId identifies the Open Banking consent resource. It does not appear in the Initiation object and has no scheme-side destination in the mapping described here.

VRP also has two journeys rather than one.

Sweeping VRP establishes authority at the consent stage and allows subsequent payments to proceed under that arrangement without the PSU ordinarily being present for each execution. Commercial VRP using delegated SCA follows a different authentication structure in which the PISP performs authentication under its arrangement with the ASPSP.

Those journeys should not be collapsed into one model of authority.

But neither changes the data-plane point. ControlParameters does not contain the creditor account. The creditor account sits separately on Data.Initiation.CreditorAccount. The object that defines the consent's operating limits and the object that identifies the payment destination are not the same object.

So Open Banking already possesses more of the machinery a conformance system would need than the card settlement plane does: an identifiable consent, explicit control parameters, and a machine-readable rejection when those controls are exceeded.

What it does not do is project that evaluation into the payment rail in a form an observer can later join back to the authority.

A single substitution

Take a grocery basket of £47.20. The mandate is pinned to a named SKU set and a £50 cap. The agent substitutes oat milk for almond. The checkout completes in one pass. No hesitation. No re-entry. No visible distress.

On the protocol plane the substitution is a meaning change. ACP can return `requires_buyer_review`. UCP can return `mandate_scope_mismatch`. Neither, on the published objects cited here, emits a signed record of the narrow amendment the user then approved — if the user was brought back at all.

On the card rail the acquiring message carries a credential or network token and the data needed to authorize a £47.20 payment. No public UK-domestic field dictionary shows the substituted SKU, the pinned SKU set, or an evaluation verdict. Net settlement at the Bank of England shows a scheme obligation, not the basket.

On Open Banking the same spend, sent as a VRP, is evaluated against `ControlParameters`. If the substitution is not a named control, the payment can pass and leave the API as an ordinary credit transfer. If a named control is breached, the ASPSP returns `U014` to the PISP and no payment reaches Faster Payments. In the pass case the rail has an unmarked payment. In the fail case the rail has no payment. Neither case leaves a joinable verdict on FPS or Bacs.

That is the measurement problem in one transaction. The session can be clean. The authority question can still be unanswerable downstream.

What the evaluation does not become

A VRP implementer will say the join already exists: the ASPSP evaluates the payment against `ControlParameters` and returns a structured error when a control is breached.

That is an evaluation. It is not a join.

The evaluation is returned to the initiating PISP on the channel that brought the request. It stops at the API boundary. `ConsentId`, which identifies the authority resource, is not the identifier that crosses onto Faster Payments. `EndToEndIdentification` is. The object that carries the operating limits and the object that identifies the creditor account are not the same object. A later observer holding only the FPS message cannot reconstruct which control was checked, whether it passed, or which consent version governed the payment.

A card-network implementer will say the mandate may already travel with the authorization message. AP2 says the payment mandate “may be shared with the network/issuer along with the standard transaction authorization messages.” Alongside, not necessarily inside. No public UK-domestic VisaNet or Banknet dictionary shows what, if any, evaluation result returns in the authorization. A private evaluation that never produces a joinable artifact held by authorized parties is observationally equivalent, for everyone not already holding the object, to no evaluation. That is a feed problem. It is not a scraping problem.

Why a larger field does not fix it

It is tempting to treat that as a message-capacity problem.

It is not.

The public Faster Payments content fields top out at 140 characters and the widest Bacs Standard 18 field identified here at 18. A full mandate-conformance object plainly does not live in those fields today.

But widening a field does not create the object that should occupy it.

A conforming Open Banking payment is released as an ordinary credit transfer with no evaluation verdict attached. A payment that fails its upstream ControlParameters check never reaches the rail.

One case emits an unmarked payment.

The other emits no payment.

That means reserving more message space, by itself, solves neither case.

The nearest retained regulatory reporting object in this corpus is the compliance data PSPs provide under the PSR's APP reimbursement standard. That reporting is aggregate: volumes and values across rejection-reason codes by reporting period. It does not provide a transaction-level payment reference or end-to-end identifier that lets an outside observer reconstruct which individual payment was evaluated and why.

The missing thing is therefore upstream of field size.

There has to be a structured per-transaction artifact to reference before message capacity has anything useful to carry.

Faster Payments and Bacs are built to move money and record that it moved. In the materials assembled here, no UK instrument requires the payment rail itself to generate or receive a machine-readable verdict answering the separate question: did this agent act inside the authority the user gave it?

Capacity was never the first bottleneck.

4. The join

Three planes fail for three different reasons, but the resulting shape is the same.

On cards, network services can perform functions against issuer-side profiles, but the available Visa documentation cited here does not establish what, if any, agent-authority evaluation result returns inside the authorization message. By the time card obligations reach the Bank of England for net settlement, individual transaction detail has disappeared from that public settlement view.

That is erasure by settlement.

On Open Banking, the authority evaluation is explicit. The ASPSP checks the payment against ControlParameters. A failure generates a structured response. But the response goes back to the PISP and stops at the API boundary. EndToEndIdentification crosses onto Faster Payments as a reconciliation reference; it is not defined as a carrier of the evaluation verdict.

That is containment by the API boundary.

On Faster Payments and Bacs themselves, there is no separate authority evaluation to lose. The rail is carrying the payment, not reproducing the upstream semantic decision about whether the payment stayed inside an agent mandate.

That is absence by design.

Erasure. Containment. Absence.

They should not be described as one technical defect because they are not one technical defect.

But they create one observational result.

The question “did the agent act inside its authority?” is answered, if it is answered at all, in the layers above the payment rail, before the money moves. The live payment message visible downstream was not built as the record of that decision.

That is the join problem.

A rich mandate can exist.

A rich checkout can exist.

A successful payment can exist.

What does not follow is that an observer possesses a durable key that proves which authority governed which transaction, what predicates were checked, whether one failed, and what happened next.

Without that join, the system can move money faster than it can explain why the money was authorized.

5. Liability is rail-dependent, not absent

The absence of a common conformance artifact does not mean the UK starts from a blank liability map.

It starts from an uneven one.

Section 75 of the Consumer Credit Act 1974 creates a statutory route to creditor liability in qualifying debtor-creditor-supplier arrangements. That structure matters here only at one remove: card-linked consumer credit already sits inside a liability regime that does not begin and end with the technical authorization result. A payment may be authorized and executed while the buyer later says the purchase was outside the authority given to the agent. Whether any particular agentic-drift dispute falls inside section 75 depends on the statutory requirements and the facts. The section is not a mandate-evaluation rule.

Account-to-account payments occupy a different protection landscape.

The PSR’s APP reimbursement policy distinguishes authorised push payment (APP) fraud from ordinary civil disputes. A payment to a legitimate supplier followed by a complaint about the goods or services is not automatically converted into APP fraud merely because the payer is dissatisfied with what was supplied.

HM Treasury’s National Payments Vision, at paragraph 3.36, recognizes the broader asymmetry between protections associated with cards and those associated with bank transfers.

The Payments Vision Delivery Committee’s Strategy Outcome 3(c) then puts the policy objective plainly: the ecosystem should “enable appropriate consumer protection across payment methods.”

That is the policy problem the missing evidence object sharpens.

Different rails can allocate different remedies. They can use different legal tests. They can place loss on different parties.

What becomes difficult is explaining those differences when the system cannot reliably reconstruct the authority state that governed the transaction.

A liability rule needs facts.

In agentic commerce, one of the most important facts may be whether the executed transaction conformed to the user’s mandate, diverged from it, or diverged and was then freshly approved.

Today that is not a fact the UK payment rails expose in a common form.

The Payment Services Regulations 2017 already ask the question the rails cannot answer. A transaction is authorized only if the payer consented to it, or to a series of which it forms part (reg. 67(1)); and where the payer denies authorizing it, the recorded use of the payment instrument “is not in itself necessarily sufficient to prove” that they did (reg. 75(3)). The test is about the scope of a consent, and the evidence rules are about the presentation of a credential. For an agent executing days after the consent was given, those two things have come apart, and the fuller argument — including why the timing rule in reg. 83 and the prospective-only withdrawal in reg. 67(4) leave revoke-and-recreate as the framework’s only remedy — is set out in the author’s response to HM Treasury’s consultation, published alongside this paper.

United States consumer-payment regulation already addresses one form of the problem — a person given an access device who then exceeds the authority given — and the answer is instructive because of its shape. Regulation E defines an unauthorized electronic fund transfer and then excludes from it a transfer initiated “by a person who was furnished the access device to the consumer’s account by the consumer, unless the consumer has notified the financial institution that transfers by that person are no longer authorized” (12 CFR §1005.2(m)). The official interpretation is explicit about the case where the delegate goes beyond the instruction: a consumer who furnishes an access device and grants authority to a person “who exceeds the authority given” is “fully liable for the transfers” unless the institution has been told that person’s transfers are no longer authorized (Comment 2(m)-2). Regulation Z says the same of credit cards in nearly the same words (Comment 12(b)(1)(ii)-3), and sends the prior question of whether authority existed at all to state law (Comment 12(b)(1)(ii)-1). The Bureau’s 2021 Electronic Fund Transfers FAQs, issued as a Compliance Aid, read “furnished” not to include credentials obtained by fraud or later theft. They do not interpret the exceeds-authority case in Comment 2(m)-2.

Whether a software agent is a “person ... furnished the access device,” whether an agent credential is an access device, and whether a capped mandate is the grant Comment 2(m)-2 describes, are not answered in Supplement I. Nothing here assumes an answer. What the rule shows is the remedy it offers for the case it does see. A payer whose delegate has exceeded the authority given has one way to stop bearing the loss: tell the institution that the delegation has ended. Not narrowed, not corrected for a single transaction — ended. That is revoke-and-recreate written into a consumer-protection rule. It is the instrument regulation 67(4) offers in the United Kingdom, and the one NatWest describes for a live variable recurring payment. Three sources, the same control shape: revoke rather than amend. The authorization rule does not supply a narrow amendment mechanism. In the case it recognizes, the control it supplies is termination.

6. The scoreboard

The industry cannot allocate a cost it has never counted, and it has never counted this one because no denominator has been defined. Four measures would define it. All four are computable from transaction-level authority, evaluation and execution records of the kind the live systems already generate or hold, but only where those records are retained and joinable, and only by the parties holding them. Nobody outside the transaction can compute them, which is why this is a feed problem rather than a scraping problem. I found none of these numbers published for the systems examined here.

The four are published separately, at driftlayer.org/papers/definitions/, under CC BY 4.0. They are quoted here rather than restated, because a definition that has two wordings has no wording.

Evaluation coverage: what share of agent-initiated transactions carry sufficient authority and evaluation evidence for conformance to be determinable at all.

The evidence in question is a signed mandate, a canonical commitment over the transaction, the evaluation criteria as pinned when the mandate was signed, and evidence of how the transaction was initiated. Anything missing one of those is neither a pass nor a failure. It is unevaluable, and nobody today publishes how many transactions are. Coverage is printed first, or the three numbers below describe only whatever happened to be visible.

Mandate conformance: among evaluable transactions, the share executing without an unapproved divergence from the governing authority.

The denominator is evaluable, mandate-bound transactions, not all agent traffic. A rate computed over everything an agent did is a statement about instrumentation rather than about conformance.

Divergence incidence: how often execution encounters a material authority mismatch, and of what type — amount, payee, item or service meaning, quantity, cumulative budget, or freshness.

Those six classes are a design taxonomy for a scoreboard, not a census of error codes already shipped one-to-one in ACP, UCP, AP2 or Open Banking v4.0.1. The live codes name a mismatch or a failed control. They do not yet publish this split. No scaling denominator is prescribed: a rate per thousand borrows its unit from card fraud reporting, and counts reported against their base carry more information because they disclose the volume a reader needs in order to read the rate at all.

Unauthorised continuation: the share of transaction value moving after an authority evaluation has failed, without a fresh user authorisation resolving the failure.

This one is a single line inside a richer measure, the divergence resolution split: of those divergences, how each ended — resolved by a signed user amendment, resolved by superseding the mandate, declined, expired unresolved, or still open — each carrying transaction value. The open bucket is not bookkeeping fussiness. No published profile identified here defines a time-out for an unresolved divergence, so folding open cases into declines invents a result.

Unauthorised continuation is the line in that split that matters: money moved after an evaluation failed, with no fresh human signature. It is the number that turns this from a safety argument into a commercial one, and none of the frameworks examined here currently publishes it.

None of these is unjukeable, and it is worth saying so plainly. A mandate written loosely enough passes everything. A transaction that was never evaluated looks clean and is a coverage miss, not a conformance hit. Changing the evaluation criteria between mandates silently changes what conformance means. Chargeback files are a biased sample of pain and must never be published as a conformance rate. A metric published with its own failure modes attached is a measurement vocabulary; one published without them is marketing.

7. The design window, and why this one

The UK governance chain runs one way.

The Payments Vision Delivery Committee, chaired by HM Treasury with the Bank of England, FCA and PSR, sets strategy and outcomes.

The Retail Payments Infrastructure Board translates that direction into design advice.

A Delivery Company, still being constituted, is intended to procure and build.

The distinction between those roles matters because the RPIB is not itself a statutory rule-maker for live payment schemes. It describes itself as a senior advisory board. A consultation response to it does not amend Faster Payments. It does not change Bacs. It does not create an Open Banking API field.

The opportunity is narrower than that.

And more useful.

The RPIB consultation asked whether capabilities including programmability and “the safe provision of agentic payments” belong in the next generation of UK retail-payments infrastructure and what those capabilities would require.

That created a place to put the evidence problem before the architecture is fixed. The author’s response to that consultation, and a second to HM Treasury’s consultation on modernizing the Payment Services Regulations, are published alongside this paper.

The consultation closed on 11 September 2026. That date should not be confused with a technical cutover. Nothing happened to the live schemes when the consultation closed. Pay.UK’s existing scheme documents continue to govern Faster Payments and Bacs. The RPIB cannot make a new field or evidence service appear by closing a consultation.

What a response could do was put a requirement into the design record that will be available to the body eventually asked to procure and build.

That is why the level of the ask matters.

“Make the field larger” is too low.

“Put the entire mandate on the payment rail” assumes the wrong object belongs in the wrong place.

The better question is architectural: if safe agentic payments require someone later to establish what authority governed a transaction, what minimum capability must the next-generation system provide so that the relevant evidence can be joined?

The RPIB’s own worked agentic-payment example demonstrates how early this design conversation remains. Its example specifies a single constraint: an amount.

The mandate problem is already richer than that. Payee. Item or service meaning. Quantity. Cumulative budget. Freshness. Amendment. Supersession. Resolution.

The design window therefore outlasts the consultation, but it is not a finished design waiting for one more field.

There is another asymmetry.

Governance speed and public visibility move in opposite directions.

Visa’s Core Rules already contain an “Agentic Platform Requirements” section in the edition dated 18 April 2026. That predates the outcome of the Bank of England’s RPIB design consultation. It also predates final establishment of Open Banking’s intended successor standards-setting body. Industry selected Open Banking Limited to convene the next phase; the Future Entity is not yet finally established.

The card scheme moved first.

But it moved on the plane that is hardest for a public observer to inspect at message level. The rule can be seen in a scheme rulebook. The authorization consequences cannot be reconstructed from a public VisaNet field manual because that manual is not public.

Faster Payments and Open Banking are slower-moving in this comparison, but their present architecture is substantially more legible from outside: dated consultation papers, versioned APIs, public mapping tables, public scheme documents.

That creates a choice deeper than speed.

A private network can move quickly and still leave the resulting evidence invisible outside the participants that hold it.

A public infrastructure design process can move more slowly but create an explicit interface for evidence that does not depend on reconstructing private messages after the fact.

For this problem, visibility is part of the capability.

The scoreboard cannot be produced by scraping public settlement data. The necessary artifacts live with transaction participants. A useful infrastructure design therefore does not merely need space. It needs a way for authorized parties to obtain or verify the evidence needed to join mandate, evaluation and payment.

That is what the design window can still affect.

Not the meaning of every future agent mandate.

Not the liability rule for every future dispute.

The ability to preserve the evidence those decisions will require.

8. The evidence object

The missing primitive can be smaller than the mandate itself.

It does not require the payment rail to become a semantic execution engine. It does not require every line item, user preference and protocol object to be pushed into Faster Payments or a card authorization message.

The proposed evidence object is the signed pair of a divergence record and the single-use amendment that resolved it.

The divergence record answers the first question: what proposed transaction failed which pinned condition of the existing authority?

The amendment answers the second: what changed, and what did the user newly authorize?

The pair creates a lineage rather than a reset.

The original mandate remains the original mandate. The divergence is recorded against it. The user's approval changes only the part that needed to change. The amendment is consumed once. The resulting transaction can then be tied to the authority state that actually permitted it.

That is more useful than a generic "buyer reviewed" flag because it preserves the thing a later evaluator needs to know: not merely that a human appeared somewhere in the journey, but what the human authorized after the system detected a mismatch.

It is also more useful than putting the whole object on the money rail.

The rail needs a joinable evidence architecture, not necessarily the evidence payload itself.

That distinction connects the protocol problem to the infrastructure problem.

The protocol needs an artifact for changing authority without destroying its lineage.

The data plane needs a way for the relevant artifacts and transaction to remain joinable.

The scoreboard needs access to those joined records.

Liability can then operate on evidence rather than inference.

Measurement precedes allocation.

The first design question is therefore not who should pay for agentic drift.

It is whether, after the money has moved, anyone can still prove that drift happened.

Endnotes

Open Banking citations below are to Standard v4.0.1 unless marked. Specification pages dated 18 March 2026; OBL announcement 1 April 2026. All Open Banking, Pay.UK, PSR and Bank of England URLs below were opened 28 August 2026.

§2 — The protocols

ACP resolution enum on message objects — recoverable, requires_buyer_input, requires_buyer_review, the last described in the file as “buyer must authorize” — [agentic-commerce-protocol/agentic-commerce-protocol, spec/2026-04-17/openapi/openapi.agentic_checkout.yaml](https://raw.githubusercontent.com/agentic-commerce-protocol/agentic-commerce-protocol/main/spec/2026-04-17/openapi/openapi.agentic_checkout.yaml), opened 14 September 2026 — https://raw.githubusercontent.com/agentic-commerce-protocol/agentic-commerce-protocol/main/spec/2026-04-17/openapi/openapi.agentic_checkout.yaml

UCP mandate_scope_mismatch — “The mandate is bound to a different checkout.” — [Universal-Commerce-Protocol/ucp](https://github.com/Universal-Commerce-Protocol/ucp/blob/v2026-08-25/docs/specification/payment/extensions/ap2-mandates.md), tag v2026-08-25, docs/specification/payment/extensions/ap2-mandates.md (error-code table) and source/schemas/common/payment_ap2_mandate.json, opened 14 September 2026 — <https://github.com/Universal-Commerce-Protocol/ucp/blob/v2026-08-25/docs/specification/payment/extensions/ap2-mandates.md>. The repository describes itself as “an open standard” under Apache-2.0 with copyright to “UCP Authors”; no corporate attribution is made here.

AP2 Human-Not-Present — [google-agentic-commerce/AP2](https://github.com/google-agentic-commerce/AP2/blob/v0.2.0/docs/ap2/specification.md), docs/ap2/specification.md at release tag v0.2.0 (28 April 2026), commit b4587ac1d055888a73b4b21750973cffba961793, whose release note states it “focuses on providing Human Not Present flows” — read 13 September 2026

§3 — The rails

Cards

ACP CheckoutSession / line_items — https://raw.githubusercontent.com/agentic-commerce-protocol/agentic-commerce-protocol/main/spec/2026-04-17/openapi/openapi.agentic_checkout.yaml

AP2 payment mandate “may be shared with the network/issuer along with the standard transaction authorization messages” — <https://ap2-protocol.org/specification/> §4.1.3, opened 14 September 2026 (the page is undated; the repository’s overview.md at release v0.2.0 has the shorter “may be shared with the network & issuer for transaction authorization”)

Card authorization chain, gateway → acquirer → scheme → issuer — PSR, Market review into the supply of card-acquiring services, Interim report Annex 1, Sept 2020 — <https://www.psr.org.uk/media/2xif1dgo/annex-1-industry-background-psr-card-acquiring-market-review-interim-report-september-2020.pdf>

Net settlement of Visa Europe / Mastercard Europe / LINK into RTGS — <https://www.bankofengland.co.uk/payments/payment-settlement> (page last updated 23 July 2026)

VisaNet / Mastercard UK-domestic ISO 8583 dictionaries not published on public developer sites searched 28 August 2026 (Visa developer documentation; Mastercard developer documentation). Absence finding, not a measured field budget.

Open Banking — v4.0.1

Pin: <https://www.openbanking.org.uk/news/obl-publishes-open-banking-standard-v4-0-1/> (1 April 2026); CEG latest version labeled v4.0.1, 18 March 2026 — <https://standards.openbanking.org.uk/customer-experience-guidelines/latest/>

VRP breach behavior, U014, and Field — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/resources-and-data-models/vrp/domestic-vrps.html>. The fetched page requires Field to carry the control parameter that caused the error. It does not state whether Field is an enumerated path or free text.

ControlParameters excludes creditor account; creditor sits on Initiation — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/resources-and-data-models/vrp/domestic-vrp-consents.html>

ConsentId scoped to the consent resource, absent from Initiation — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/resources-and-data-models/pisp/domestic-payment-consents.html>

EndToEndIdentification → FPS; no pass/fail evaluation field in the cited mapping — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/references/domestic-payment-message-formats.html>

VRP profile (control parameters; non-sweeping may defer some values to payment time) — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/profiles/vrp-profile.html>

Sweeping VRP / subsequent payments without the PSU ordinarily present — OBL VRP-for-sweeping good-practice guidelines v4.0.1, 18 March 2026 — <https://standards.openbanking.org.uk/good-practice/vrp-for-sweeping-guidelines/latest/>

FPS / Bacs

FPS field sizes: tag 120 = 18, tag 62 = 31, tag 121 = 140 — Pay.UK FPS System Principles v11, Jan 2026 — <https://www.wearepay.uk/wp-content/uploads/2026/02/Pay.UK-Faster-Payments-System-Principles-v-11-Jan-2026.pdf>

Widest public Bacs Standard 18 field = 18 characters — <https://www.bacs.co.uk/media/1cqbf21x/iso20022bacstranslationguide.pdf>

Breach → payment not sent — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/resources-and-data-models/vrp/domestic-vrps.html>

APP compliance-data reporting standard, aggregate field list — <https://www.psr.org.uk/media/egvjalcq/psr-compliance-data-reporting-standards.pdf>

§4 — The join

Visa VCTC documentation; available documentation silent on what evaluation result returns in the authorization — <https://developer.visa.com/capabilities/vctc/docs> — absence finding, not a positive claim about message contents

Net settlement removing transaction-level detail from the Bank of England settlement view — <https://www.bankofengland.co.uk/payments/payment-settlement>

ControlParameters breach returned to PISP, with no scheme-side projection identified — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/resources-and-data-models/vrp/domestic-vrps.html>

EndToEndIdentification → FPS — <https://openbankinguk.github.io/read-write-api-site3/v4.0.1/references/domestic-payment-message-formats.html>

FPS field list — Pay.UK FPS System Principles v11, Jan 2026 — <https://www.wearepay.uk/wp-content/uploads/2026/02/Pay.UK-Faster-Payments-System-Principles-v-11-Jan-2026.pdf>

§5 — Liability

Payment Services Regulations 2017 (SI 2017/752), regs. 67, 75 and 83 — <https://www.legislation.gov.uk/ukSI/2017/752/contents> — quoted as in the author’s response to HM Treasury, 13 September 2026

Consumer Credit Act 1974, s. 75(1) — “he shall have a like claim against the creditor, who, with the supplier, shall accordingly be jointly and severally liable to the debtor” — <https://www.legislation.gov.uk/ukpga/1974/39/section/75> (revised version as at 7 January 2026), opened 14 September 2026

PSR civil-dispute exclusion — Payment Systems Regulator, PS25/5, APP scams reimbursement: consolidated policy statement, May 2025, ¶¶3.3–3.4

National Payments Vision ¶3.36 — “Currently, card payments offer greater consumer protection than payments via bank transfer.” — https://assets.publishing.service.gov.uk/media/6736385fb613efc3f182317a/National_Payments_Vision..pdf (verified 10 September 2026)

PVDC Strategy, Outcome 3(c) — see the §7 entry for the Strategy URL

12 CFR §1005.2(m) and Official Interpretation Comment 2(m)-2 — <https://www.consumerfinance.gov/rules-policy/regulations/1005/2/>, opened 14 September 2026

CFPB, Electronic Fund Transfers FAQs (Compliance Aid), answers dated 4 June 2021 and 13 December 2021 — <https://www.consumerfinance.gov/compliance/compliance-resources/deposit-accounts-resources/electronic-fund-transfers/electronic-fund-transfers-faqs/>, opened 13 September 2026. Cited only for the reading of “furnished”; not an official interpretation under Appendix C.

12 CFR §1026.12, Official Interpretation Comments 12(b)(1)(ii)-1 and 12(b)(1)(ii)-3 — <https://www.consumerfinance.gov/rules-policy/regulations/1026/12/>, opened 14 September 2026

NatWest, “How do I amend a VRP (variable recurring payment) or sweeping payment?” — “You cannot amend an active payment (sweeping and / or VRP), if you want to change an existing permission you must revoke and set-up a new one.” — read 13 September 2026; cited as one institution’s description of its own product

§6 — The scoreboard

Kirby, M. T. (2026) Four Measures for Mandate Conformance. Version 1, 10 September 2026 — <https://driftlayer.org/papers/definitions/> — the four definitions are quoted from this page without alteration

§7 — The design window

PVDC / RPIB / DeliveryCo chain; RPIB as a “senior advisory board” — <https://www.bankofengland.co.uk/payment-and-settlement/the-national-payments-vision/retail-payments-infrastructure-board> ; PVDC Strategy, 7 November 2025 — https://assets.publishing.service.gov.uk/media/690de7a247ad122f854627bf/PVDC_Strategy.pdf

Consultation questions on programmability / agentic payments; closed 11 September 2026; Box G single constraint — <https://www.bankofengland.co.uk/paper/2026/cp/rpib-consultation> — independently re-verified 28 August 2026

Visa Core Rules, “Agentic Platform Requirements,” §4.1.24, edition 18 April 2026; existence sourced, verbatim rule text not extracted — <https://usa.visa.com/dam/VCOM/download/about-visa/visa-rules-public.pdf>

Future Entity not finally established; OBL selected to convene the next phase — HMT, Modernising Payment Services Regulation, 14 July 2026; FCA independent assessment page, updated 1 May 2026 — <https://www.fca.org.uk/publications/external-research/independent-assessment-proposals-establish-open-banking-standards-setting-body>

§8 — The evidence object

The signed pair of a divergence record and a single-use amendment is specified in Kirby, M. T., Mandate Lifecycle Extensions for Agentic Payment Credentials, Technical Disclosure Commons, Defensive Publications Series no. 11517, August 2026, CC BY 4.0 — https://www.tdcommons.org/dpubs_series/11517 — with a reference implementation at <https://mandatepatch.org> (Apache-2.0). This paper cites the specification and does not argue for it; the requirement described here is more general than any one implementation of it.

Limits

Seams

1. Protocol divergence → payment rails. The prose treats mandate drift as a checkout/protocol problem; §§3–4 treat observability after the payment leaves checkout. The join works only if those are kept as two separate planes. That method is stated at the close of §2. The £47.20 substitution in §3 is a worked example for walking one meaning-change across those planes; it is not a cited live transaction. This text does not imply that the card or A2A rail itself creates the original semantic divergence.
2. Rail invisibility → liability. Section 3 establishes that the payment movement does not expose a common authority verdict. Section 5 starts from a different proposition: legal protections can still exist without that verdict. Missing payment metadata is not missing legal rights.

3. Scoreboard → governance. The scoreboard requires artifacts held by transaction participants; the RPIB cannot order those artifacts into today's rails. The bridge is capability design: whether the future infrastructure should make evidence joinable, not whether the consultation can impose a live reporting regime.

What was left out

Earlier drafts of this paper contained the following. Each was removed for want of a primary source, or because it overstated the case.

An earlier draft's dynamic-linking claim was removed: it was an inference from PSRs 2017 reg 100(2), not a proposition stated by an Open Banking or FCA primary document.

Reserved-message-fields language remains out. An unmarked conforming payment plus no payment at all on failure cannot be repaired by increasing field capacity.

The "on Earth" universal, the motive claim about attributable cost, the "Liability Timebomb" heading, and any characterization of American Express Agent Purchase Protection remain out.

Section 75(4) is no longer used as if it were a mandate-evaluation rule.

The Regulation E error-resolution clocks, the §1005.6 dollar tiers, and the 2021 FAQ catalogue beyond the reading of "furnished" remain out of this paper.

Two further limits

I am not a lawyer. Everything above is a reading of the instruments as published, and the questions it raises are questions for people who are.

Whether a software agent is a "person ... furnished the access device" under Regulation E is undecided, and it determines whether any of this reaches the United States liability layer at all. The same limit applies to whether an agent credential is an access device and whether a capped mandate is the grant Comment 2(m)-2 describes.